

UNIT 1 INTRODUCTION



What is Cyber Security

- ❑ ***Cyber Security*** is similar to physical security or any other type of security for that matter.
- ❑ Physical security helps in protecting physical properties and other valuables and prevents humans from performing any accidental damage or crime on those. In the same way, Cyber Security allows organizations to protect their computer systems, end-user applications, ***data privacy***, etc. from any form of malicious cyberattacks and other external ***threats***.
- ❑ The main aim of this technology is to avoid cybercriminals and attackers from accessing, corrupting, or making any changes to the systems, applications, and data of an organization.

Why to learn Cyber Security?

- There was a huge data breach of 50 million Facebook accounts recently happened in March 2018 by a firm known as Cambridge Analytic which harvested data for US Election Predictions. The data breach came to the limelight and Facebook has levied a fine since they didn't protect user details and due to their lack of transparency in the system.
- Imagine such a big firm like Facebook is susceptible to such data breaches, so Cyber security is an important measure for every organization. Cyber security is used to avoid data breaches, and protect the integrity of networks and systems from attacks.
- cybersecurity is a subcategory of information security.

Syllabus



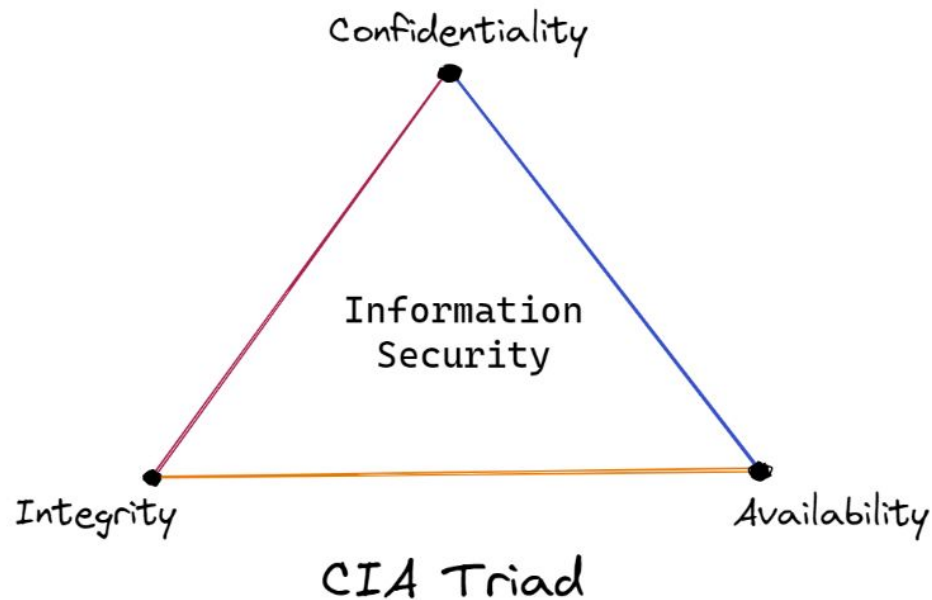
- Introduction, Elements of Information Security, Security Policy, Techniques, Steps, Categories, Operational Model of Network Security, Basic Terminologies in Network Security. Threats and Vulnerability, Difference between Security and Privacy

What is information Security?

- information security or InfoSec, is a set of tools and practices that you can use to protect your digital and analog information.
- It is a process of securing your personal data from unauthorized access, usage, revelation, interruption, modification, or deletion of data.
- Information Security aims to safeguard the privacy, availability, and integrity of data and stop online threats like hacking and data breaches.

What are the Principles of Information Security?

- To protect sensitive information, three principles of Information Security are being widely used, to guide the advancement of security measures and protocols.

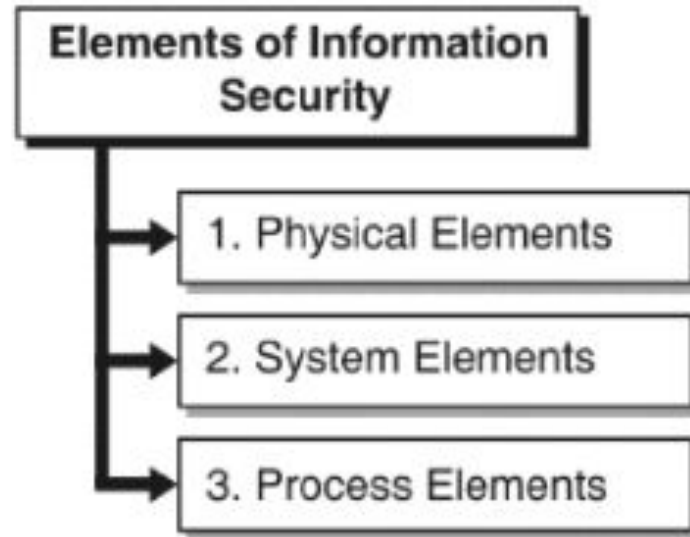


Cont..

- **Confidentiality:** Confidentiality ensures that information is accessible only to authorized individuals or systems. It involves preventing unauthorized access, disclosure, or exposure of sensitive data.
 - ◆ **Implementation:** Encryption, access controls, and secure communication channels are employed to protect information from being accessed or viewed by unauthorized parties.
- **Integrity:** Integrity ensures the accuracy, reliability, and consistency of information throughout its lifecycle. It involves safeguarding data from unauthorized modification, alteration, or corruption.
 - ◆ **Implementation:** Hash functions, digital signatures, and access controls are used to verify the integrity of data. Regular monitoring and auditing also help identify and address any unauthorized changes.
- **Availability:** Availability ensures that information and resources are accessible and usable when needed. It involves preventing disruptions, downtime, or denial of service that could impact the availability of critical systems and data.
 - ◆ **Implementation:** Redundancy, backups, disaster recovery planning, and proper maintenance practices contribute to ensuring the availability of information and systems.

Elements of Information Security

- Three major elements of information security are defined as the following:



1. Physical Elements: (Guard, Camera, Rzone, Downloading, Access Rights)
2. System Elements: (Antivirus, Malicious software detection solution, Disable USB)
3. Process Elements: (Authentication and Access control, software entry, log details)

Physical Elements

- physical security is the protection of your people, property and assets. This includes the physical protection of equipment and tech, including data storage, servers and employee computers.



Each business' individual physical security risks will be different, but there are some common types of physical security threats to be aware of..

1. **Unauthorized entry (Access Control)**
2. **Theft and burglary**
3. **Infrastructure protection**
4. **Staff training and incident response**
5. **Unauthorized device uses in organization**
6. **Unwanted Downloading**

- Physical security is crucial, and security teams must work together to ensure the security of digital assets.

System Element..

- System elements in information security refer to the fundamental components, processes, and entities within a computer system or network that contribute to the overall security of information.
- These elements work together to protect the confidentiality, integrity, and availability of data. Here are the key system elements in information security:
- **Software Security:** Protecting software applications and systems from vulnerabilities and unauthorized access.
 - ◆ **Examples:** Secure coding practices, regular software updates and patches, application firewalls.
- **Endpoint Security:** Securing individual devices (endpoints) to prevent unauthorized access and protect against malware.
 - ◆ **Examples:** Antivirus software, endpoint detection and response (EDR), mobile device management (MDM).
- **Access Controls:** Regulating access to systems, applications, and data based on user roles and permissions.
 - ◆ **Examples:** Role-based access control (RBAC), access control lists (ACLs), least privilege principle.

Process Elements

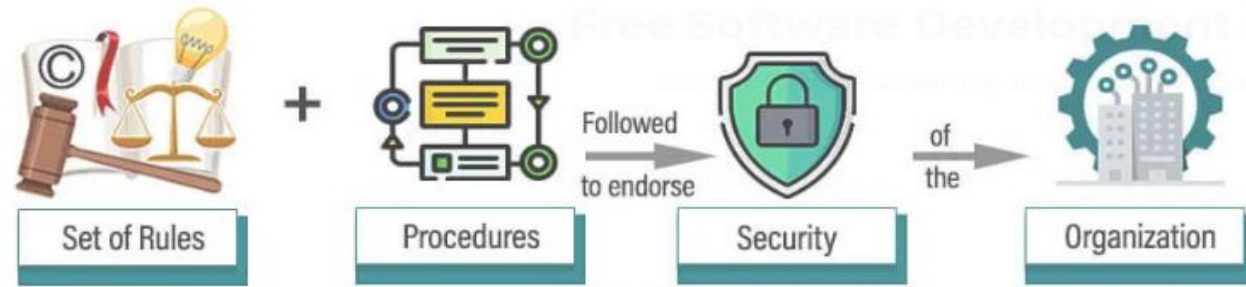
- Process elements refer to the organized and systematic procedures, workflows, and activities that are established and implemented to manage, monitor, and improve the security of information assets within an organization.
- Here are the key of process elements in information security:
 - ◆ **Access Control Management Process:** Regulating access to systems, applications, and data based on user roles and permissions.
 - **Activities:** User provisioning, access reviews, privilege management, and deprovisioning.
 - ◆ **Security Incident Logging and Monitoring Process:** Continuously monitoring system activities and maintaining logs for analysis and audit purposes.
 - **Activities:** Log collection, analysis, correlation, alerting, and reporting.

Need of security policy

- The need for a security policy in an organization arises from various factors and challenges associated with managing information technology and protecting sensitive data.

- Security policies serve as a crucial foundation for establishing and maintaining a secure computing environment. Here are some key reasons highlighting the need for security policies:
 - ◆ **Protecting Information Assets**
 - ◆ **Mitigating Security Risks, system fraud, system misuse detection**
 - ◆ **Establishing a Security Culture**
 - ◆ **Ensuring Business Continuity**
 - ◆ **Protecting Reputation and Trust**
 - ◆ **Etc....**

Security Polic



- A security policy in information security is a formal document that outlines an organization's approach to protecting its information assets.
- It serves as a set of guidelines and rules that define the security requirements, responsibilities, and procedures to be followed by individuals, systems, and processes within the organization.
- The primary purpose of a security policy is to establish a framework for safeguarding sensitive information, mitigating risks, and ensuring the confidentiality, integrity, and availability of data.
- Regular reviews and updates to these policies are necessary to address emerging threats and changes in the organizational environment.

Common policies

Staff Access Rights

- Setting out who should be able to view what
- Access should be limited to only those who need it – **tiered levels of access**

Risk Assessments

- Regular checks on the current risks and how ready the organisation is to defend

			Impact			
			0 Acceptable	1 Tolerable	2 Unacceptable	3 Intolerable
			Little or No Effect	Effects are felt but not too serious	Serious Impact in terms of Action and Resources	Could Result in Damages
Likelihood	Improbable	Not likely to occur				
	Possible	May well occur				
	Probable	May well occur				

Responsibilities of Staff

- The expectations on how to use the IT securely, e.g.

"Set complex passwords"

"Don't write down logins"

"Encrypt all personal data"

"Don't use USB sticks"

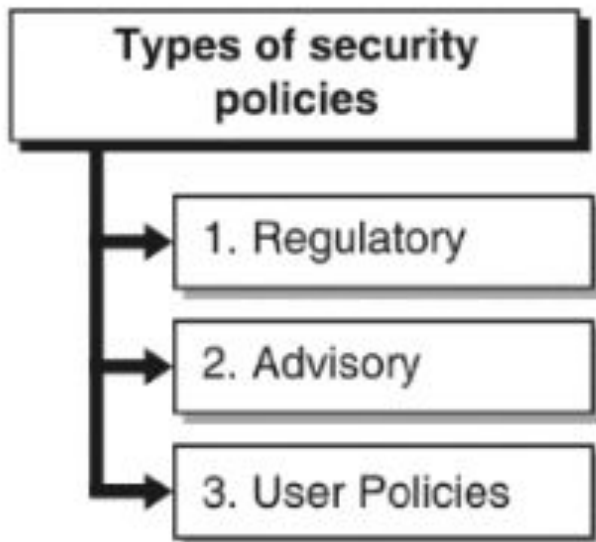
Common Policies

Effectiveness of Protection Measures

- Reviewing the current measures
- May set out **when** and **how** the current measures are tested

Types of Security Policy

- Security policies can be categorized into various types based on their focus, scope, and purpose within an organization. Here are some common types of security policies:



Cont..

- **Regulatory:** This policy ensure that organization should follow the some specific industry regulations. These policies are security policies that an organization must implement due to compliance, regulation, or other legal requirements.
- **Advisory:** Advisory policy strongly advises employees on the behaviors and activities which should and should not take place within the organization. These policies are not mandatory but are strongly suggested, perhaps with serious consequences defined.
- **User policies or Informative:** Informative policies are policies that exist simply to inform the reader. There are no implied or specified requirements, and the audience of this information could be internal i.e. within the organization or external parties.
 - ❖ Example: User Id and Password get changed frequently or get disable when he or she left organization 2) Use of internet in office.

7-Steps for Creating your Security Policy

1. Identify the need for having a particular policy. Does it align with your security objectives and goals? Who does it affect? What would happen in the absence of this policy?
2. Get approval from the management and stakeholders to develop a security policy.
3. Perform a risk analysis to identify vulnerabilities in your IT environment. And then prioritize risks based on their potential consequences.
4. Create a comprehensive first draft security policy and get feedback from legal, IT, HR, and other stakeholders. Once the feedback is in, make necessary changes and finalize the policy.
5. Train your employees, and ensure that they understand the scope, purpose, and consequences related to the policy.
6. Publish the security policy and inform stakeholders, customers, contractors, and everyone who has access to the resources of your organization. Work with your web team to publish public policies on your website.
7. Regularly review and update your policy to meet evolving security requirements, also monitor the efficiency and compliance of the security policy by performing timely vulnerability and penetration testing. Ensure compliance through internal audits and maintain a good security posture.

Security Techniques

- Commonly used security technique



Cont..

□ **Firewalls:**

- ◆ **Network Firewalls:** Control and monitor incoming and outgoing network traffic based on predetermined security rules.
- ◆ **Host-based Firewalls:** Protect individual devices by monitoring and controlling network traffic at the device level.

□ **Encryption:**

- ◆ **Data Encryption:** Secure sensitive data by converting it into a code that can only be deciphered with the appropriate encryption key.
- ◆ **Communication Encryption:** Use protocols like HTTPS, TLS, or VPNs to secure data in transit.

□ **Intrusion Detection and Prevention Systems (IDPS):**

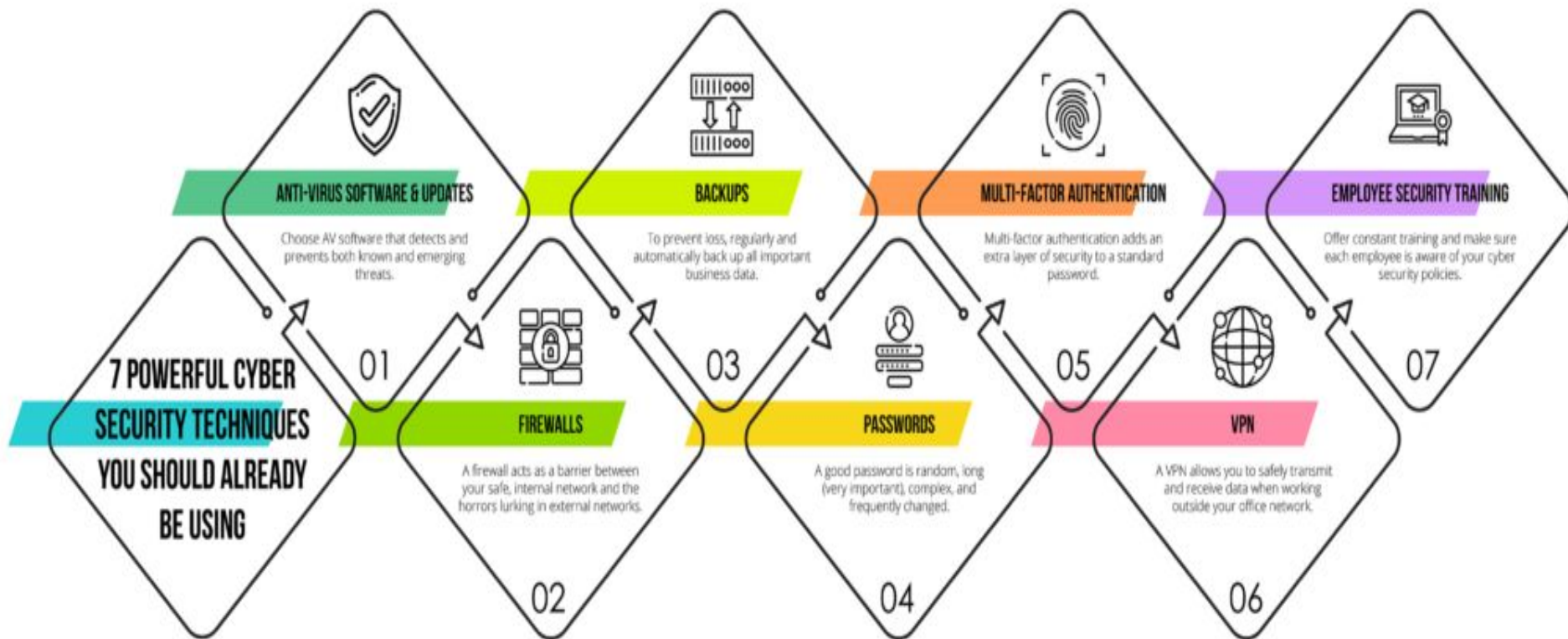
- ◆ **Detect:** Monitor network and/or system activities for malicious activities or security policy violations.
- ◆ **Prevent:** Automatically respond to detected incidents by blocking or preventing further malicious activities.

Cont..

- **Backup and Recovery (Data Loss Prevention):**
 - ❖ Regularly back up critical data and implement a robust disaster recovery plan to minimize the impact of data loss or system failures.
- **Antivirus and Anti-malware Software:**
 - ❖ Regularly update and use antivirus software to detect and remove malicious software, such as viruses, worms, and Trojans.
- **Security Policies (Training and Awareness):**
 - ❖ Educate users and employees about security best practices, social engineering attacks, and the importance of maintaining a secure computing environment.
- These security techniques should be implemented as part of a comprehensive and layered approach to ensure the protection of digital assets and information. Additionally, security measures should be regularly updated and adapted to address evolving threats and technologies.

7 Powerful cyber security techniques

- **Anti-Virus Software & Updates**
- **Firewalls**
- **Backups**
- **Passwords**
- **Multi-Factor Authentication**
- **virtual private network (VPN)**
- **Employee Security Training**



Steps in provide security to information or computer system

□ **Risk Assessment:**

- ❖ Identify and assess potential risks to your information and computer systems.
- ❖ Evaluate the impact and likelihood of various security threats.

□ **Create a Security Policy:**

- ❖ Develop and document a comprehensive security policy that outlines organizational security objectives, user responsibilities, and acceptable use policies.

□ **Access Control:**

- ❖ Implement strong authentication mechanisms, such as multi-factor authentication (MFA).

□ **Data Encryption:**

- ❖ Encrypt sensitive data, both in transit and at rest, using strong encryption algorithms.
- ❖ Ensure that encryption keys are securely managed and updated regularly.

Cont..

□ **Firewalls:**

- ❖ Deploy firewalls to control and monitor incoming and outgoing network traffic.
- ❖ Configure firewalls to block unauthorized access and only allow necessary services.

□ **Regular Software Updates and Patch Management:**

- ❖ Keep operating systems, software, and applications up to date with the latest security patches.
- ❖ Establish a patch management process to ensure timely updates.

□ **Antivirus and Anti-malware Solutions:**

- ❖ Install and regularly update antivirus and anti-malware software to detect and remove malicious software.

□ **Incident Response Plan:**

- ❖ Develop an incident response plan outlining the steps to be taken in the event of a security incident.

Cont..

□ **Security Awareness Training:**

- ❖ Educate users and employees about security best practices, social engineering tactics, and the importance of reporting suspicious activities.

□ **Backup and Recovery:**

- ❖ Implement a regular backup strategy for critical data.
- ❖ Test backup and recovery procedures to ensure data can be restored in the event of data loss or system failure.

□ **Security Monitoring and Logging:**

- ❖ Implement security information and event management (SIEM) solutions to monitor and analyze security events.
- ❖ Retain logs for an appropriate duration for auditing and forensic purposes.

□ **Regular Security Audits and Assessments:**

- ❖ Conduct periodic security audits and vulnerability assessments to identify and address potential weaknesses.
- ❖ Use penetration testing to simulate real-world attacks.

Categories of Computer Security

- Computer security encompasses various measures and techniques to protect computer systems, networks, and data from unauthorized access, attacks, and damage.



Cont..

□ **Network Security:**

- ◆ **Firewalls:** Hardware or software-based barriers that control incoming and outgoing network traffic based on predetermined security rules.
- ◆ **Intrusion Detection and Prevention Systems (IDPS):** Monitor network or system activities for malicious activities or security policy violations.

□ **Endpoint Security:**

- ◆ **Antivirus and Antimalware:** Software designed to detect, prevent, and remove malicious software from computer systems.
- ◆ **Host Intrusion Prevention Systems (HIPS):** Monitors and controls the behavior of applications to prevent malicious activities.

□ **Application Security:**

- ◆ **Secure Coding Practices:** Developing software with security considerations to prevent vulnerabilities.
- ◆ **Web Application Firewalls (WAF):** Protects web applications from various attacks such as SQL injection and cross-site scripting.

Cont..

- **Information Security:**

- ◆ **Encryption:** Converts data into a secure format to prevent unauthorized access.
- ◆ **Data Loss Prevention (DLP):** Controls and monitors sensitive data to prevent unauthorized access or sharing.

- **Optional Security:**

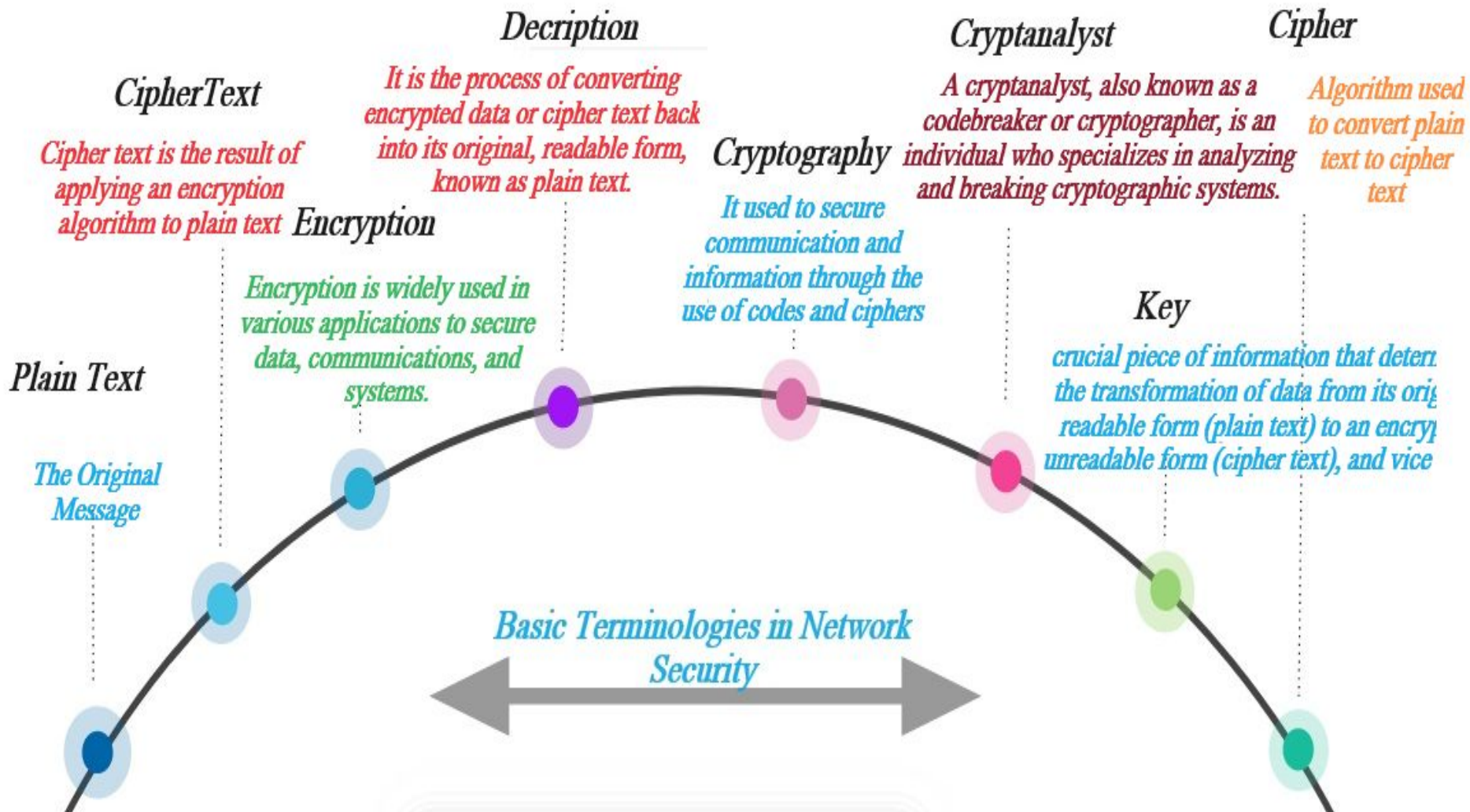
- ◆ **Access Controls:** Restricts physical access to computer systems and data centers.
- ◆ **Surveillance:** Monitors and records activities in and around physical locations.

- **Disaster Recovery and Business Continuity:**

- ◆ **Backup and Recovery:** Regularly backing up data and having a plan for its recovery in case of data loss.
- ◆ **Business Continuity Planning (BCP):** Ensures the continuity of critical business operations in the event of a disaster.

- *These types of computer security work together to create a comprehensive defense against a wide range of cyber threats.*

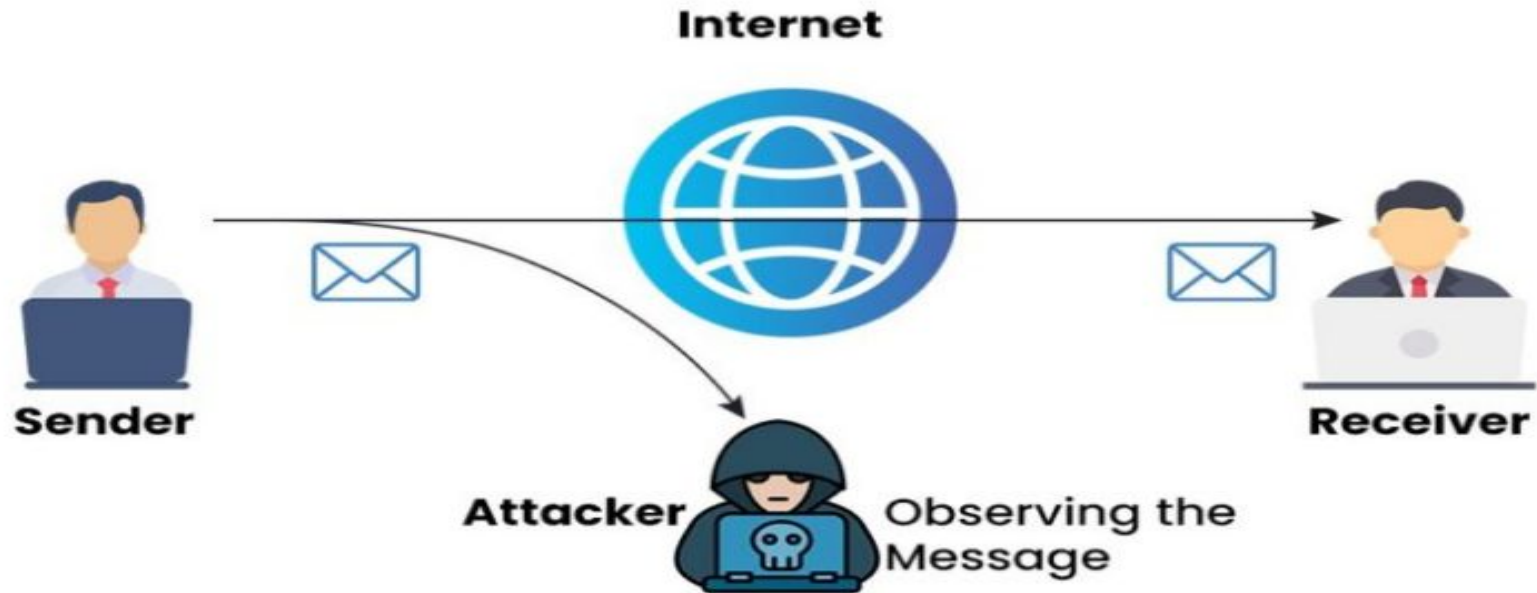
Basic Terminology of network security



Security Attacks

- A network attack is an attempt to gain unauthorized access to an organization's network, with the objective of stealing data or perform other malicious activity. OR A *network attack* can be defined as any method, process, or means used to maliciously attempt to compromise network security.
- There are two main types of network attacks:
 - ◆ **Passive:** Attackers gain access to a network and can monitor or steal sensitive information, but without making any change to the data, leaving it intact.
 - ◆ **Active:** Attackers not only gain unauthorized access but also modify data, either deleting, encrypting or otherwise harming it.

Passive Attack



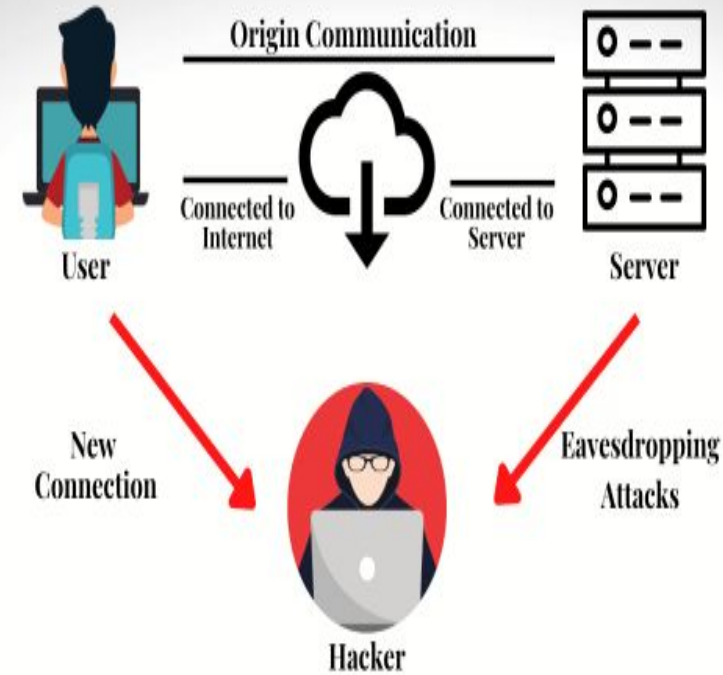
- ❑ In passive assaults, the attacker just monitors in on messages and steals any information they can get their hands on.
- ❑ They have dedicated themselves to monitoring every message and gathering information.
- ❑ The attacker does not attempt to change the content of the information he steals.
- ❑ These assaults pose a serious danger to the privacy of your information but can do no actual damage to the system.

Cont..

- Since no data or information modification is involved, Passive attacks are harder to detect than Active ones. As a result, the attacked person has no idea they are being attacked.
- Whenever sender identifies this kind of attacks he can use encryption methods to send his data. Now intruder can not read this information. But using traffic analysis he can identify source and destination of packets.
- **Type of Passive Attacks**
 - ◆ **Eavesdropping:**
 - ◆ **Traffic analysis.**

Cont..

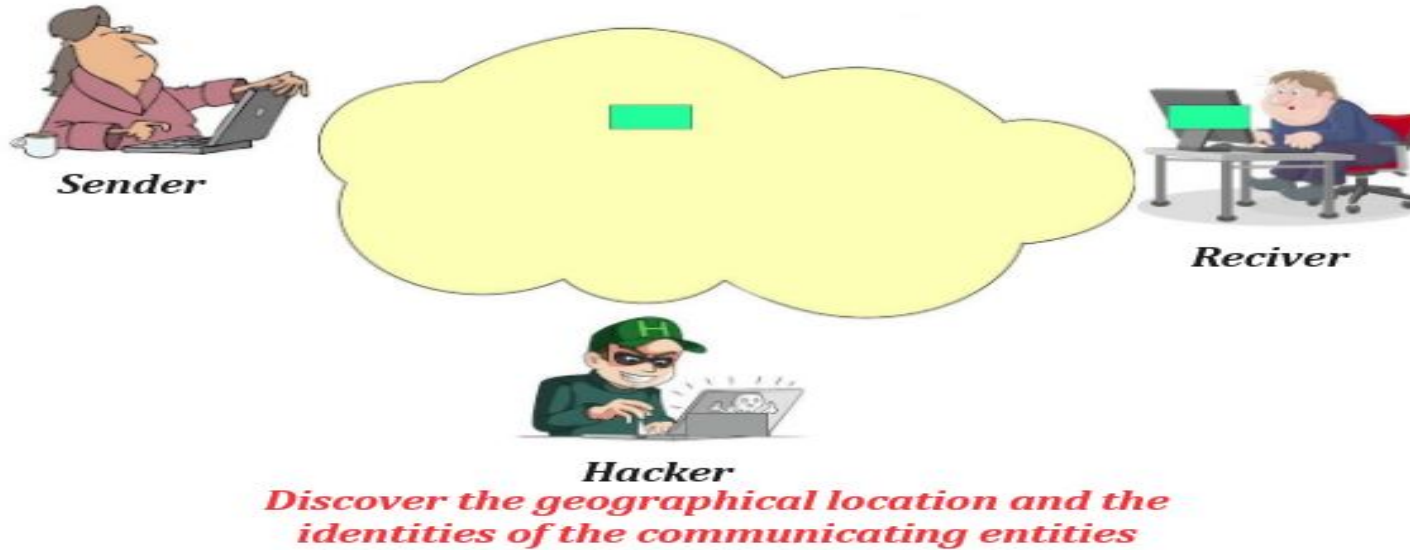
- **Eavesdropping:** In this type of attack, the attacker secretly listens to a conversation or communication that is not intended for him. It can be done for various purposes, such as gathering information, spying, or blackmailing



- The attacker looks for important financial and corporate data that can be monetized for illicit purposes. Because network transmissions appear normal, eavesdropping attacks can be difficult to detect.
- An eavesdropping cyber attack involves a weaker network connection between a client and a server that can be used by the attacker to reroute network traffic to be successful. On a computer or a server, the attacker downloads and installs special network monitoring software with the name “sniffer” that will seek out and report (intercept) sensitive data communications as they are being transferred.

Cont..

- **Traffic analysis:** Traffic analysis is a passive attack that focuses on observing the exchange of information between two entities to extract valuable information.



- Even the encrypted data can be used by attackers to discover the geographical location and the identities of the communicating entities, along with details regarding the frequency and duration of the exchanged messages. This information is valuable in determining the nature of the ongoing communication.

Active Attack



- An active attack is a type of cyberattack in which a hacker attacks a system and modifies the data or the information per his requirements to perform malicious tasks.
- During active attacks, the attacker takes an active role in an attempt to gain unauthorized access to a system or network. To do that, they can perform various malicious activities, such as injecting malware, launching a denial-of-service (DoS) attack, or altering data. An active attack typically aims to gain control over the system or steal data.
- When an active attack happens, the victim gets informed about the attack as the data changes or modifies. And, because of the data modification, these attacks greatly threaten the integrity and availability of data

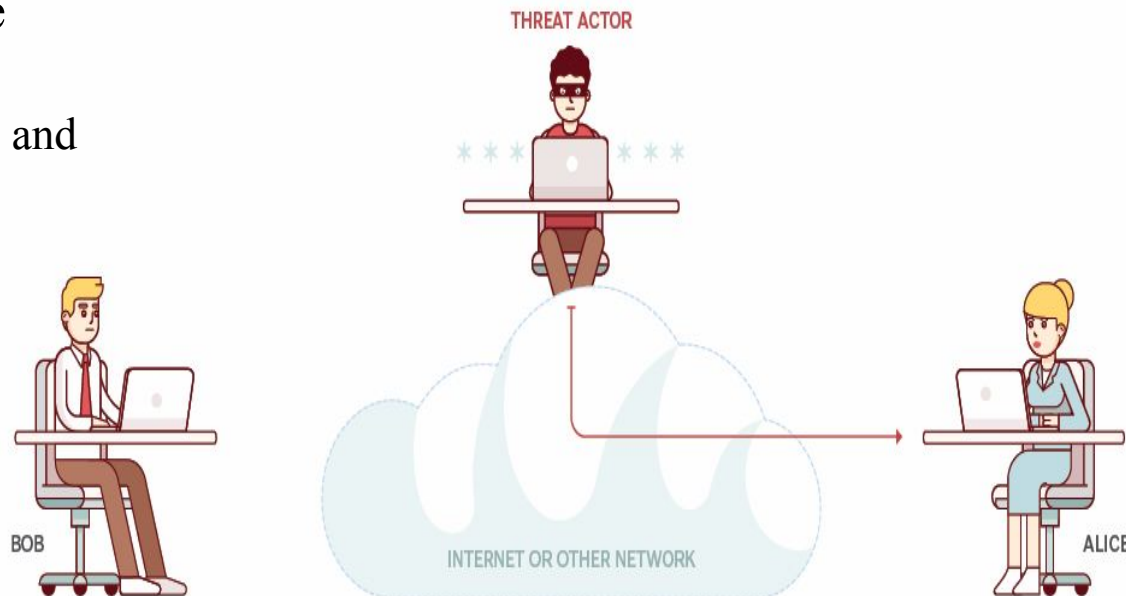
Types of active attack

- **Masquerade:** In this type of attack, the attacker disguises himself and pretends to be a legitimate user. With this, the attacker can easily steal sensitive information, which can cause many security issues for the user.

- Masquerade attacks are conducted in several different ways, including the following:

1. using stolen login identifications (IDs) and passwords;
2. finding security gaps in programs; and
3. bypassing the authentication

In an email masquerade attack, the attacker uses stolen login information or access via another security gap to send a message to Alice that looks like it's from Bob.



Cont..

- ❑ **Message Modification:** In this type of attack, the attacker modifies or delays the original information or data for its own benefit
- ❑ Message modification attacks are commonly email-based attacks.
- ❑ The attacker takes advantage of security weaknesses in email protocols to inject malicious content into the email message. The attacker may insert malicious content into the message body or header fields.

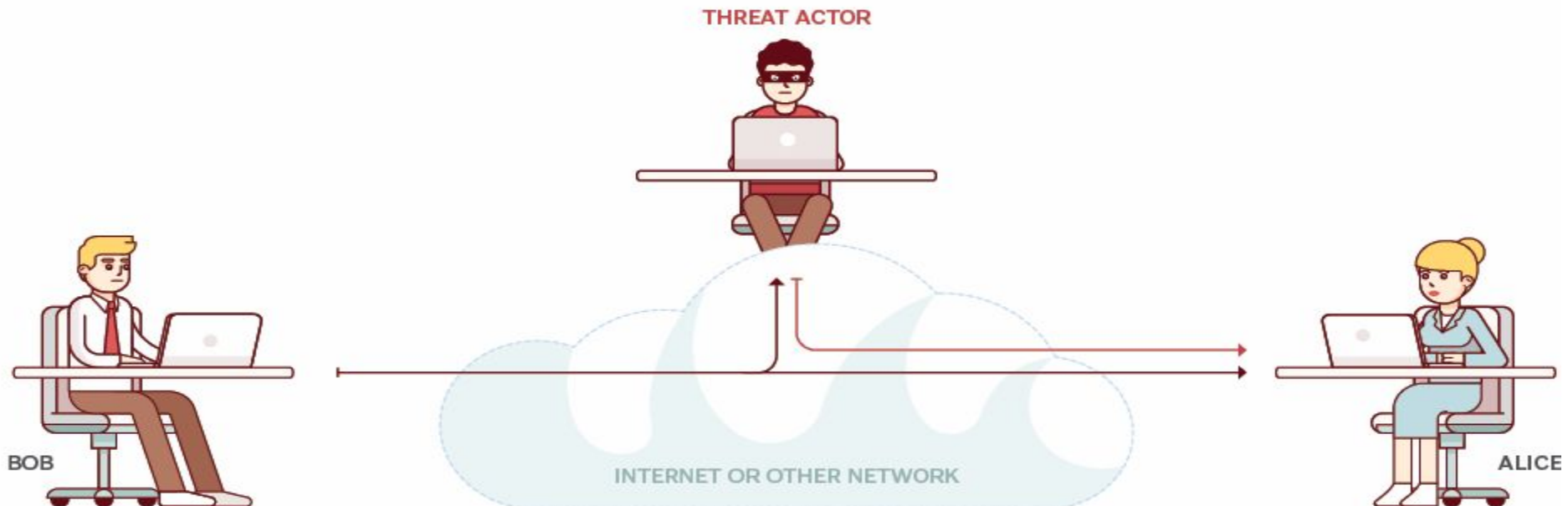
In a message modification attack, the attacker captures a message from Bob, changes it and then sends it on to Alice, who thinks the message is from Bob.



Cont..

- **Replay Attack** : It is also known as an session hijacking attack. A replay attack refers to the act of capturing and transmitting a message with the intention of generating an authorized result.
- the threat actor gets a copy of a message and resends it to the recipient who is fooled into thinking it's coming from the original sender.

In an email replay or hijacking attack, the attacker uses nefarious means to capture a message Bob sent to Alice and then replays it to get information or access from Alice, who thinks she's communicating with Bob.



Cont..

- **DOS attack:** It stands for Denial-of-Service attacks. In this type of attack, the attacker floods the system with fake requests or data in order to make a service, website, or server unavailable.
- A denial of service (DoS) attack is designed to slow down networks or systems, making them inaccessible to users. Devices, information systems, or other resources on a machine or network, such as online accounts, email, e-commerce websites, and more, become unusable during a denial of service



Cont..

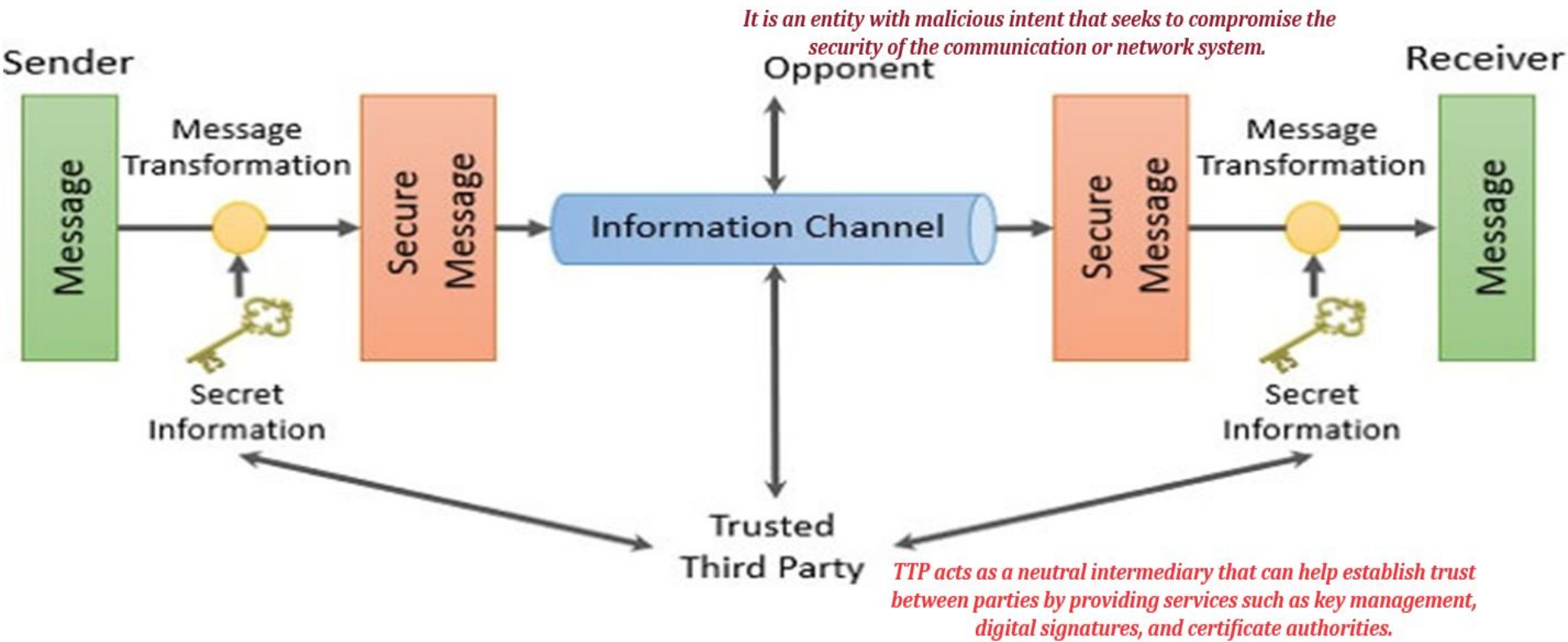
- Here are some examples of active attacks:
 - ◆ **Phishing:** In this attack, the hacker attempts to gain unauthorized access to a computer system to size, modify, or steal data.
 - ◆ **Man-in-the-Middle:** In this attack, the hacker catches and transmits communications between two parties who assume they are talking directly with one another
 - ◆ **Ransomware:** In this attack, the hacker uses malware to prevent a user or organization from accessing files on their computer.

Difference between Active and Passive Attack

Parameters	Active Attacks	Passive Attacks
Objective	To change or disrupt data or systems.	To collect or observe information.
Impact	Data integrity, availability, or confidentiality may be compromised; system functionality or performance may be degraded or disrupted; unauthorized access or control may be gained.	Data confidentiality may be compromised; system behaviour or configuration may be revealed; network topology or activity may be mapped.
Detection	Easier to detect due to changes or anomalies in data or systems.	Harder to detect due to the lack of changes or anomalies in data or systems.
Prevention	It can be prevented or mitigated by using encryption, authentication, authorization, firewall, antivirus, etc.	It can be prevented or mitigated by using encryption, obfuscation, masking, tunneling, etc.
Duration	The duration of the active attack is lower compared to the passive attack.	The duration of the passive attack is much longer as it is based on observing the data for as much time as possible.
Example	Denial-of-service, replay.	Eavesdropping, sniffing, traffic analysis.

Network Security Model

- A **Network Security Model** exhibits how the security service has been designed over the network to prevent the opponent from causing a threat to the confidentiality or authenticity of the information that is being transmitted through the network.

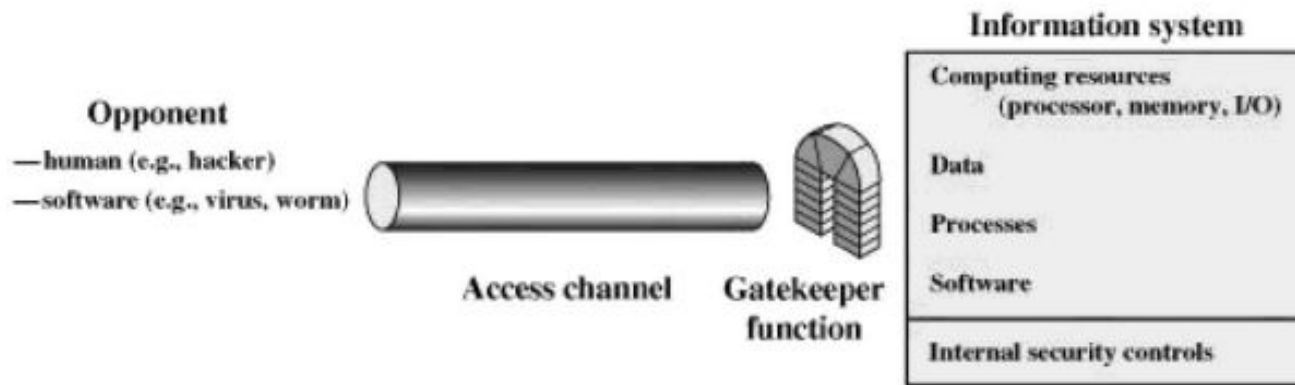


Cont..

- A message is to be transferred from one party to another using Internet service.
- The two parties sender and receiver, they must cooperate for the exchange to take place. A logical information channel is established by defining a route through the Internet from source to destination and by the cooperative use of communication protocols (e.g., TCP/IP) by the two principals.
- Original message of the sender going to **transform a readable message at the sender side into an unreadable format**, an appropriate algorithm should be designed such that it should be difficult for an opponent to crack that security algorithm.
 - ◆ **Secret information** is used while transforming the message which will also be required when the message will be retransformed at the recipient side. That's why a trusted third party is required which would take the responsibility of distributing this secret information to both the parties involved in communication
- An appropriate methodology must be used to deliver the secret information to the communicating parties without the interference of the opponent (use of communication protocols (e.g., TCP/IP) by the two principals.)
- When receiver received an message then **cipher text converted to plain text using decryption algorithm**

Network Security Access Model

- Security considerations come into play when it is essential or desirable to protect the transmission of information from a potential threat to its confidentiality, integrity, and more.



- This is important to secure **sensitive data** safe from cyber attacks and to ensure that the network is usable and can be trusted
- Network security protects the data of the client by ensuring that hackers can not get into your network easily.

Cont..

- You are well aware of the attackers who attack your system that is accessible through the internet. These attackers fall into two categories:
- **Hacker:** The one who is only interested in penetrating into your system. They do not cause any harm to your system they only get satisfied by getting access to your system.
- **Intruders:** These attackers intend to do damage to your system or try to obtain the information from the system which can be used to attain financial gain.

Cont..

- The attacker can place a logical program on your system through the network which can affect the software on your system. This leads to two kinds of risks:
- **a. Information threat:** This kind of threats **modifies data** on the user's behalf to which actually user should not access. Like enabling some crucial permission in the system.
- **b. Service threat:** This kind of threat **disables** the user from accessing data on the system.
- Well, these kinds of threats can be introduced by launching worms and viruses and may more like this on your system. Attack with worms and viruses are the software attack that can be introduced to your system through the internet.

Cont..

- There are two ways to secure your system from attacker of which the first is to introduce the **gatekeeper function**. Introducing gatekeeper function means introducing **login-id** and **passwords** which would keep away the unwanted access.
- In case the unwanted user gets access to the system the second way to secure your system is introducing **internal control** which would detect the unwanted user trying to access the system by analyzing system activities. This second method we call as **antivirus** which we install on our system to prevent the unwanted user from accessing your computer system through the internet.

Threat and Vulnerability



- To understand the difference among risk, threat, and vulnerability, it is first important to learn what is an asset in the world of cyber security.
- Asset: Asset includes people, property, and information.
 - ❖ People includes employees and other stakeholders of an organization
 - ❖ property means both tangible and intangible items carrying some value
 - ❖ information means any kind of useful data such as databases, software code, company accounts and records, etc.
- Every now and then, these assets are exposed to a threat, risk, and vulnerability.

What is Vulnerability?

- A vulnerability in cyber security refers to any weakness in an information system, system processes, or internal controls of an organization.
- Vulnerability in Cyber Security means any weakness the attackers can use to gain access to your systems.
- Cyber Security Vulnerabilities can act as a gateway or entry point for future cyber-attacks and intrusions. Hackers will constantly test out these areas of weakness and can exploit them if they see an opportunity.
- Examples of vulnerability:
 - ❖ A weakness in a firewall that can lead to malicious hackers getting into a computer network
 - ❖ Lack of security cameras
 - ❖ Unlocked doors at businesses

Examples



Outdated Software



Misconfigured Systems



Unprotected APIs



Weak Credentials



Lack of Strong Encryption



Zero Day Vulnerabilities



Unauthorised Access

- seven types of Cyber Security Vulnerabilities with examples.
- 1. **Outdated software:** A system that uses software that is not up to date can compromise the security of the host system and leave the entire network vulnerable. **Example:** Using an out-of-date antivirus software or operating system.
- 2. **Misconfigured Systems:** If a system is not configured according to the organisation's security policy, that would also result in Vulnerabilities. **Example:** Using a system that doesn't contain the organisation's safety and monitoring tools.
- 3. **Unprotected APIs:** APIs act like a bridge between applications and the internet. In an organisation, APIs are most likely used in a private network to secure the communication between the Applications and their components that require internet access. **Example:** Sharing access to your cloud drives with unauthorised individuals or trying to access them in an unprotected public

Cont..

4. **Weak Credentials:** People often use the same set of passwords for almost all applications and logins. **Example:** Using a weak password like 1234, Abcde or using a password with a pattern like using Birthdays and names like James1956.
5. **Lack of Strong Encryption:** Although encryption can't prevent Hacking, it can slow down the attacking momentum. **Example:** Try encrypting files using a password when transferring data. This option is available in simple file types like WinZip and WinRAR; many software is available for professional-level encryption.
6. **Zero Day Vulnerabilities:** A zero-day Vulnerability is a flaw or set of weaknesses uncovered by an attacker but is unknown to the software developer and the organisation that uses the software. **Example:** Any attack that went unnoticed from a few days to several weeks until it's discovered can be considered a Zero-day Vulnerability.
7. **Unauthorised Access:** When an organisation gives its employees more access than necessary, it could also lead to a data breach. **Example:** Restricting access to install, modify or remove any software tool and only giving such access to System

Threats

- Threat is any potential hazard that is likely to harm an organization, whether intentionally or unintentionally, associated with the exploitation of an existing vulnerability.
- There are three main categories of threats: intentional, unintentional, and natural:
 - ◆ Intentional threats are actions or methods that are used by bad actors to compromise a security or software system. Examples of intentional threats include malware, ransomware, phishing, and malicious code.
 - ◆ Unintentional threats are often caused by human error. For example, an employee might forget to lock the door to the IT servers or leave sensitive information unmonitored. These types of mistakes can leave an organization vulnerable to threats.
 - ◆ Natural threats are unpredictable events such as floods, hurricanes, earthquakes, and other natural disasters that have the potential to damage an organization's assets. While these threats are not typically related to cybersecurity, it's important to consider them since they can impact an organization's assets.

Risk

- Risk is the probability of loss of asset, exposure to threat, and potential damage from a cyberattack.
- It is basically the meeting point of threat and vulnerability.



1. Examples of risk include:

1. Financial losses
2. Loss of privacy
3. Damage to your reputation Rep
4. Legal implications
5. Even loss of life

Risk can also be defined as:

$$Risk = Asset + Threat \times Vulnerability$$

Difference between Security and Privacy

S.No	Privacy	Security
1	Privacy is the appropriate use of user's information	Security is the "confidentiality, integrity and availability" of data
2	Privacy is the ability to decide what information of an individual goes where	Security offers the ability to be confident that decisions are respected
3	The issue of privacy is one that often applies to a consumer's right to safeguard their information from any other parties	Security may provide for confidentiality. The overall goal of most security system is to protect an enterprise or agency [72]
4	It is possible to have poor privacy and good security practices	However, it is difficult to have good privacy practices without a good data security program
5	For example, if user make a purchase from XYZ Company and provide them payment [13] and address information in order for them to ship the product, they cannot then sell user's information to a third party without prior consent to user	The company XYZ uses various techniques (Encryption, Firewall) in order to prevent data compromise from technology or vulnerabilities in the network

Insem Examination Question

▣ *Feb 2023---30 Marks*

- Q1)** a) List and explain various elements of Information Security. [5]
b) Write difference between security and privacy. [5]

OR

- Q2)** a) Enlist the security goals and mechanisms. [5]
b) Draw and explain operational security model for network security. [5]

- Q3)** a) Define cyber security. Explain Active and passive attack. [5]
b) Explain Feistel cipher. [5]

OR

- Q4)** a) Explain ceaser cipher with example. [5]
b) Explain DES Algorithm. [5]



Thank you

!!!!!!